ANALISIS Y PLANIFICACION DEL PENTEST (ACTIVIDAD 1)

Dana Paola Martínez Hernández

HACKER WOMEN COUNCIL – ETHICAL HACKING

INDICE

HISTORIAL DE VERSIONES 1
OBJETIVOS DEL PENTEST 2
ALCANCE 2
AUTORIZACIÓN Y CONDICIONES 2
TIPO DE PENTEST.....3
PLANIFICACION.....3
FASES DEL PENTES 4
INVESTIGACIÓN 4

HISTORIAL DE VERSIONES

NUMERO DE VERSION	NOMBRE	FECHA	DESCRIPCION DE LOS CAMBIOS
1.0	Dana Paola Martínez Hernández	03/09/2026	Documento creado
2.0	Dana Paola Martínez Hernández	19/09/2026	Correcciones de contenido y ampliación de justificaciones técnicas.

OBJETIVOS DEL PENTEST

El propósito de realizar esta evaluación de seguridad a Aurora Market es identificar y corregir cualquier vulnerabilidad en la página web antes de que un atacante real la pueda aprovechar. Para esto, buscamos conocer a fondo cómo funcionan los mecanismos de inicio de sesión y los controles de acceso, asegurándonos de que ningún usuario pueda ver la información privada de otra cuenta ni acceder sin permiso al panel de administración para modificar productos o datos del sistema. También nos interesa evaluar las entradas de texto del sitio frente a fallas comunes como inyección SQL o XSS, que podrían poner en riesgo la base de datos y la estabilidad de la tienda. Al final, este pentest le aporta a Aurora Market el valor de conocer el estado real de su seguridad y la tranquilidad de que la información de sus clientes está protegida, permitiéndoles operar con confianza y evitar pérdidas económicas o de reputación.

ALCANCE

- SE EVALUARÁ

1. La plataforma web principal de Aurora Market (proceso de inicio de sesión, registro y perfiles de usuario).
2. El módulo de compras (mecanismos del carrito, catálogo de productos y consulta de pedidos).
3. El panel de administración web (interfaz para gestionar productos, usuarios y pedidos).
4. Los formularios e insumos de datos que se conectan con la base de datos de la app.

- NO SE EVALUARÁ

1. Redes sociales de la empresa o de los empleados.
2. Equipos personales (laptops, celulares) y cuentas de correo del personal.
3. Proveedores externos y sistemas de terceros que no forman parte del alcance acordado.
4. Cualquier acción que interrumpa deliberadamente el funcionamiento de la plataforma o altere/elimine información real de los clientes.

AUTORIZACIÓN Y CONDICIONES

- PERMISOS REQUERIDOS:

    1. Se solicitará un contrato formal y la carta de autorización firmada por Aurora Market para validar legalmente las pruebas y delimitar el alcance.
    2. Se requerirá el acceso a credenciales de prueba con diferentes niveles de privilegio para evaluar tanto a usuarios normales como a administradores.
    3. Se mantendrá una vía de comunicación directa con un contacto técnico de la empresa para reportar inmediatamente cualquier hallazgo crítico.

- CONDICIONES ACORDADAS:

    1. Las evaluaciones se realizarán principalmente en horarios nocturnos o de bajo tráfico para no interrumpir la experiencia de las personas que estén comprando.
    2. Se mantendrá un respeto estricto del alcance limitándonos solo a la aplicación web, evitando involucrar al personal o sus correos corporativos.
    3. Se ejecutarán únicamente pruebas no destructivas para no alterar la base de datos real ni tumbar el sitio web.

TIPO DE PENTEST

- CAJA GRIS (Gray-Box):

- Se selecciona esta modalidad debido a que se cuenta con información parcial del sistema, como la estructura general de la aplicación web y el acceso a credenciales de prueba con diferentes niveles de privilegio.
- Permite simular el comportamiento de un atacante que posee cierto conocimiento previo o de un usuario autenticado que intenta elevar sus accesos, sin necesidad de tener el código fuente completo ni los diagramas internos de la infraestructura.

PLANIFICACION

- **OBJETIVOS:** Evaluar autenticación, probar entrada de datos (SQLi/XSS) y verificar el control de acceso del panel administrativo.
- **ALCANCE:** Evaluar únicamente la plataforma web de Aurora Market (login, compras, panel admin), dejando fuera a los empleados y evitando cualquier acción que interrumpa el funcionamiento de la plataforma o altere/elimine información de los clientes.
- **PERMISOS Y CONDICIONES:** Carta de autorización firmada, credenciales de prueba por roles y ejecuciones nocturnas de bajo tráfico.
- **METODOLOGÍA A UTILIZAR**: OWASP.
- **RECOPILACIÓN DE INFORMACIÓN PREVIA:** Para recopilar la información del sitio se utilizará una combinación de fuentes abiertas (OSINT) y fuentes internas. Primero, con OSINT se buscarán datos públicos sobre Aurora Market (como subdominios o tecnologías expuestas en internet) sin interactuar directamente con su servidor. Después, se usarán las fuentes internas (las credenciales de prueba que nos da el cliente) para revisar desde adentro el comportamiento de los diferentes roles de usuario en la plataforma.
- **RECURSOS NECESARIOS:** Las herramientas seleccionadas para esta fase y su propósito son: **Wappalyzer:** Una extensión del navegador para identificar rápidamente qué tecnologías web usa el sitio (tipo de servidor, lenguajes y frameworks) de forma pasiva. **Nmap:** La utilizaré para escanear el servidor web, identificar qué puertos están abiertos (como HTTP o HTTPS) y conocer qué servicios y versiones están activos.

OWASP ZAP / Burp Suite: Las usaré como proxy de intercepción para analizar el tráfico entre el navegador y la página web. Esto me permitirá revisar cómo viajan las galletas de sesión, inspeccionar formularios y probar fallas de seguridad en las peticiones.

- **PROGRAMACIÓN DEL PENTEST:** Las pruebas técnicas se realizarán en un horario nocturno, de **00:00 a 05:00 hrs**. Se propone este rango debido a que durante esos horarios se registra el menor tráfico de compras. De esta forma se evita saturar el servidor, interrumpir la experiencia de los clientes o causar caídas no deseadas durante las horas activas del negocio.

FASES DEL PENTEST

1. **RECONOCIMIENTO:** En esta primera fase se enfocará en conocer la estructura de Aurora Market antes de realizar cualquier prueba técnica directa. Primero identificar posibles puntos de entrada analizando la aplicación web y escaneando los puertos del servidor con **Nmap**. El análisis de puertos servirá para descubrir qué servicios están corriendo en el servidor, qué versiones utilizan y si hay puertos o servicios innecesarios expuestos que puedan representar un riesgo.
2. **ANÁLISIS DE VULNERABILIDADES:** Para esta etapa utilizaré **OWASP ZAP** (o **Burp Suite**). Su propósito será interceptar las peticiones entre mi navegador y la plataforma para analizar a detalle cómo se procesa la información en el inicio de sesión, los formularios y el carrito de compras. Buscaré detectar fallas de validación de entradas (como inyección SQL o Cross-Site Scripting / XSS) y errores de lógica que permitan el acceso no autorizado o la manipulación de datos.
3. **EXPLOTACIÓN:** Probar de forma segura si es posible acceder a datos de otros usuarios o elevar privilegios al panel de administración sin autorización.
4. **POST-EXPLOTACIÓN**: Determinar el alcance del impacto (por ejemplo, si se podría modificar la base de datos o consultar información sensible) sin alterar el sitio real.
5. **INFORME:** Documentar todas las vulnerabilidades encontradas, su nivel de riesgo y las recomendaciones técnicas para que Aurora Market las solucione.

INVESTIGACIÓN

- METODOLOGIA ELEGIDA**:**

    - OWASP: Se elige esta metodología estandarizada por ser la referencia internacional más reconocida para evaluar la seguridad en aplicaciones web y comercio electrónico.

- ¿POR QUE SERIA UTIL PARA ESTE PROYECTO?:

    - Organización para el auditor: Permite saber exactamente por dónde empezar y qué fallas específicas buscar (como inyecciones SQL o errores de autenticación), evitando revisiones al azar o perder tiempo en áreas secundarias.
    - Confiabilidad para la empresa: Al seguir un protocolo avalado a nivel mundial, Aurora Market tiene la garantía de que la evaluación es rigurosa, profesional y cubre los riesgos reales.
    - Lenguaje técnico universal: Genera un reporte claro que cualquier equipo de desarrollo o ciberseguridad posterior podrá entender y aplicar fácilmente para corregir las vulnerabilidades.